

Speech de Exposición — Caso Bankitor: Arquitectura de Seguridad TO-BE

SLIDE 1 — PORTADA

"Buenas tardes. El trabajo que vamos a presentar hoy aborda el Caso Bankitor, una entidad financiera peruana que sufrió dos incidentes críticos de seguridad. El objetivo fue diseñar una arquitectura de seguridad TO-BE — es decir, el estado futuro al que debe evolucionar Bankitor — estructurada en tres horizontes: corto, mediano y largo plazo. Todo el trabajo está guiado por el modelo de Defense in Depth que hemos estudiado en el curso."

SLIDE 2 — CONTEXTO DEL PROBLEMA

"Bankitor lleva más de diez años operando en el mercado financiero peruano, está regulada por la SBS y ya cuenta con TSI instaladas y un SOC tercerizado. Sin embargo, sufrió dos incidentes que no pudo investigar correctamente.

El primero: un cambio en el router de borde dejó sin Internet a la organización. Cuando intentaron hacer el análisis forense, no había registro de qué comandos se ejecutaron ni quién los ejecutó. El router no tenía trazabilidad.

El segundo: los saldos de deuda en la base de datos de créditos fueron modificados masivamente a cero. El análisis forense no pudo determinar si fue un DBA, una aplicación o un atacante. La BD no tenía auditoría SQL.

Adicionalmente, la Banca por Internet estaba expuesta sin WAF — un riesgo latente que todavía no había explotado, pero que representaba una brecha de alto impacto. Estos tres problemas son el punto de partida de nuestra propuesta."

SLIDE 3 — DEFENSE IN DEPTH — MODELO DE CIBERSEGURIDAD

"Toda nuestra arquitectura está ordenada bajo el modelo de Defense in Depth, o DiD. Es importante aclarar que DiD no es una estrategia en sí misma — es un modelo o abordaje de ciberseguridad. La estrategia incluye además el apetito de riesgo y la priorización del negocio.

Lo que hace el DiD es definir cinco capas de protección independientes: Perímetro, Red, Host, Aplicación y Data. Cada control que vamos a proponer se ubica en una de estas capas, de forma que si una falla, las demás siguen protegiendo.

Ahora bien, el profesor nos ha señalado que el DiD tiene tres defectos. Primero: asume una ruta lineal basada en la arquitectura de red. Segundo: puede generar capacidades superpuestas o discontinuas entre capas. Tercero: tiene una perspectiva limitada de amenazas — no incorpora el Kill Chain, ni inteligencia, ni capacidad de respuesta automatizada.

Por eso, en el largo plazo nuestra arquitectura evoluciona para corregir precisamente esos tres defectos."

SLIDE 4 — EVOLUCIÓN DEL MARCO: DiD → ZERO TRUST

"La evolución de nuestra arquitectura sigue tres momentos.

En el corto plazo, aplicamos DiD puro: cerramos las brechas críticas usando las cinco capas del modelo.

En el mediano plazo, maduramos el DiD: agregamos detección activa y segmentamos la red interna con VLANs — que son en sí mismas múltiples perímetros internos.

En el largo plazo, incorporamos Zero Trust sobre el DiD. Y aquí es importante aclarar: Zero Trust no reemplaza al DiD — se construye sobre él. Zero Trust requiere que ya existan MFA, PAM, VLANs y SIEM maduros, que son exactamente lo que construimos en el corto y mediano plazo. Zero Trust agrega el principio de 'nunca confíes, siempre verifica' a cada acceso, sin importar si viene de dentro o fuera de la red."

SLIDE 5 — CLASIFICACIÓN DE ACTIVOS — BUSINESS-CRITICAL SUBSET

"Antes de proponer controles, identificamos cuáles son los activos más críticos de Bankitor. Usamos el concepto de Business-Critical Subset — la intersección entre servicios, activos de información y sistemas físicos.

Los cinco activos prioritarios son: la Base de Datos de Créditos, con valoración 5 — crítico — porque fue el activo comprometido en el Incidente 2. La Banca por Internet, valoración 5, porque es el canal expuesto sin protección. Los Routers de Borde de ambos datacenters, valoración 5, porque fueron el punto de falla del Incidente 1. Los datos de clientes, valoración 5

por cumplimiento SBS. Y el Firewall y Balanceador, valoración 4 — severo — porque son puntos únicos de falla en el AS-IS.

Todos los controles que proponemos están orientados a proteger este conjunto."

SLIDE 6 — DIAGRAMA AS-IS

"Este es el estado actual de Bankitor. Señalando el diagrama: pueden ver que el tráfico de Internet entra por dos routers — uno por datacenter — pero esos routers no tienen AAA ni TACACS+, por eso no hay trazabilidad de comandos.

El balanceador y el firewall son únicos — un solo punto de falla. Si caen, cae toda la operación.

La red interna es plana — no hay segmentación entre los sistemas de los usuarios, los servidores de aplicación y la base de datos de créditos. Un atacante que entre a cualquier punto puede moverse libremente.

Y la Banca por Internet, que está en la DMZ, no tiene WAF.

En resumen: baja trazabilidad, poca segmentación y detección insuficiente."

SLIDE 7 — DIAGRAMA CORTO PLAZO (0–3 meses)

"Este es el diagrama de la arquitectura que proponemos implementar en los primeros tres meses. Voy a recorrerlo de arriba hacia abajo siguiendo el flujo del tráfico.

En la parte superior tenemos Internet — zona no confiable. El tráfico entra por dos ISPs independientes, uno para cada datacenter, lo que ya nos da redundancia de enlace.

El primer componente que encuentra el tráfico son los Routers de Borde. Aquí está la solución al Incidente 1: implementamos AAA con TACACS+. TACACS+ registra comando por comando, con el usuario, la hora y el resultado. Si alguien hace un cambio en el router, queda registrado en el SIEM. Algo que antes era imposible de investigar, ahora tiene trazabilidad completa.

Luego tenemos el AntiDDoS en cada datacenter — ya existía, lo mantenemos.

El Balanceador ahora es HA — alta disponibilidad. Tenemos dos balanceadores en modo activo-pasivo. Si el principal cae, el secundario asume sin impacto.

Después viene el WAF — Web Application Firewall. Esta es la solución al riesgo latente de Banca por Internet. El WAF opera en capa 7 del modelo OSI — la capa de aplicación — y filtra

ataques como SQL Injection, Cross-Site Scripting, bots y ataques de fuerza bruta, antes de que lleguen al servidor web.

El Firewall Perimetral también pasa a ser HA — ya no hay punto único de falla.

El firewall divide el tráfico hacia dos zonas. A la izquierda, la DMZ, donde está el servidor web de Banca por Internet, con hardening, TLS 1.2/1.3 y EDR. A la derecha, la Red Interna, donde está la Base de Datos de Créditos. Aquí está la solución al Incidente 2: implementamos Auditoría SQL, que registra cada INSERT, UPDATE o DELETE sobre la BD — incluyendo qué usuario lo ejecutó, desde qué aplicación y a qué hora.

En la parte inferior, el SIEM recibe los logs de absolutamente todos los componentes — las líneas punteadas del diagrama representan ese flujo de logs. El SOC tercerizado monitorea 24x7 con casos de uso configurados específicamente para los incidentes de Bankitor.

Finalmente, en la esquina derecha: el acceso administrativo. Los administradores de TI ya no acceden directamente a los equipos críticos. El flujo es: MFA → VPN → Bastion Host → Equipos. Sin MFA, no hay acceso."

SLIDE 8 — CORTO PLAZO: TABLA DE CONTROLES

"Esta tabla resume lo que acabamos de ver en el diagrama, pero con la perspectiva del modelo DiD. Cada control tiene su capa asignada y el problema que resuelve.

AAA con TACACS+ en capa Perímetro resuelve el Incidente 1. Auditoría SQL en capa Data resuelve el Incidente 2. El WAF en capa Aplicación cierra el riesgo latente de Banca por Internet. El Syslog centralizado es transversal — alimenta el SIEM con logs de todos los componentes. El Balanceador y Firewall HA eliminan los puntos únicos de falla. MFA con VPN y Bastion controlan el acceso administrativo. Y el SIEM con casos de uso permite que el SOC detecte en tiempo real."

SLIDE 9 — DIAGRAMA MEDIANO PLAZO (3–6 meses)

"En el mediano plazo construimos sobre todo lo que ya implementamos en el corto plazo — no reemplazamos nada, ampliamos.

Los cambios más importantes que vemos en este diagrama son cuatro.

Primero: IDS/IPS. Aparece a la derecha del firewall, posicionado entre el firewall y la red interna. Detecta y bloquea intrusiones en tiempo real — escaneos de red, exploits conocidos,

comunicación con servidores de comando y control, y movimiento lateral entre zonas. Este componente requiere calibración, por eso no lo pusimos en el corto plazo.

Segundo: VLANs en la red interna. Donde antes teníamos una red plana, ahora vemos cinco segmentos separados. VLAN 10 para usuarios, VLAN 20 para servidores de aplicación, VLAN 30 para la base de datos de créditos, VLAN 40 para administración y el PAM, y VLAN 50 para backups. Las reglas entre VLANs son estrictas: un usuario no puede hablar directamente con la base de datos. Las VLANs crean múltiples perímetros internos — el DiD no solo tiene un perímetro externo.

Tercero: PAM — Privileged Access Management — aparece a la derecha, como un módulo separado. El PAM reemplaza al Bastion básico del corto plazo. Agrega bóveda de contraseñas, grabación de sesiones completas en video y texto, rotación automática de contraseñas después de cada sesión, y acceso just-in-time — solo se otorga acceso cuando se necesita y por el tiempo mínimo necesario.

Cuarto: abajo a la izquierda vemos el DLP básico — previene que datos sensibles salgan por correo o proxy. Y a la derecha, Gestión de Vulnerabilidades con escaneo periódico y priorización por CVSS.

El SIEM en la base ahora recibe eventos de todas estas nuevas fuentes — IDS/IPS, PAM, VLANs, DLP y el escáner de vulnerabilidades."

SLIDE 10 — MEDIANO PLAZO: TARJETAS DE CONTROLES

"Esta vista resume los cinco controles principales del mediano plazo. IDS/IPS en capa Red para detectar movimiento lateral. PAM en capas Aplicación y Data como reemplazo del Bastion. VLANs en capa Red que crean los dominios de seguridad internos. Gestión de Vulnerabilidades en capa Host para encontrar brechas antes de que el atacante las explote. Y DLP básico en capa Data para controlar la exfiltración."

SLIDE 11 — MEDIANO PLAZO: TABLA DE CONTROLES

"La tabla completa del mediano plazo. Noten que el Hardening de protocolos elimina Telnet, FTP, SSHv1 y TLS antiguo — versiones 1.0 y 1.1 que son vulnerables y que la propia SBS ya no acepta. Y las Pruebas de Continuidad validan que el BCP realmente funciona — hacemos failover real del firewall, el balanceador y el ISP, y medimos los tiempos."

SLIDE 12 — DIAGRAMA LARGO PLAZO (6–12+ meses)

"El largo plazo es el salto de una postura reactiva a una proactiva. Voy a señalar los componentes nuevos más importantes.

En la esquina superior derecha: Threat Intelligence. Feeds de IPs maliciosas, indicadores de compromiso — IoCs — y TTPs actuales, con monitoreo específico del sector financiero a través de FS-ISAC. Este componente alimenta tanto al WAF como al SIEM en tiempo real. Si una IP aparece en los feeds de inteligencia, el WAF la bloquea automáticamente sin necesidad de intervención humana.

Justo debajo del balanceador: el API Gateway. Este componente es nuevo y tiene un rol específico: controla y autentica todo el tráfico entre APIs. Autentica las llamadas, aplica rate limiting para prevenir abuso, valida el esquema de las peticiones, enmascara datos sensibles en las respuestas y tiene circuit breaker para aislar servicios que fallan. El API Gateway complementa al WAF — no lo duplica — y esto corrige el Defecto 2 del DiD: capacidades superpuestas.

El WAF ahora está integrado con los feeds de Threat Intelligence — bloquea automáticamente las IPs maliciosas conocidas.

El firewall incorpora microsegmentación — más granular que las VLANs del mediano plazo, segmenta a nivel de carga de trabajo individual. Esto corrige el Defecto 1 del DiD: la ruta lineal basada en la arquitectura de red.

La red interna ahora es la zona de Zero Trust. Cada VLAN aplica el principio 'nunca confíes, siempre verifica'. La VLAN 10 de usuarios tiene EDR con Zero Trust endpoint. La VLAN 20 de servidores de aplicación solo puede hablar con la BD en puertos específicos. La VLAN 30 de la Base de Datos de Créditos tiene auditoría SQL, sin salida propia y con enmascaramiento de datos. La VLAN 40 de administración tiene PAM y es monitoreada por UEBA en tiempo real.

En la parte inferior vemos la Plataforma de Operaciones de Seguridad. El elemento más importante aquí es el SOAR — automatiza la respuesta a incidentes con playbooks. Si una IP ataca el WAF más de cien veces en cinco minutos, el SOAR la bloquea automáticamente. Si se detecta una modificación masiva en la BD de créditos, el SOAR bloquea el acceso, genera una alerta crítica y escala al CISO — todo en segundos, sin esperar a que un analista lo note. Esto corrige el Defecto 3 del DiD: sin respuesta.

El UEBA — User and Entity Behavior Analytics — establece una línea base de comportamiento normal de cada usuario y entidad, y detecta anomalías mediante machine learning. En el caso del Incidente 2: si hubiera existido UEBA, habría detectado que ese DBA estaba actualizando cien mil filas de golpe, algo completamente fuera de su patrón normal, sin necesidad de una regla específica.

Finalmente, la capa de Gobierno: DevSecOps, Gobierno CISO con KPIs y alineación a NIST CSF e ISO 27001, BCP probado, concientización, Bug Bounty y Auditoría externa."

SLIDE 13 — LARGO PLAZO: DEFECTOS DiD Y CONTROLES

"Esta slide conecta directamente con la teoría del curso. Los tres defectos del DiD que identificó el profesor, y cómo nuestra arquitectura los corrige.

Defecto 1 — arquitectura lineal: lo corregimos con microsegmentación por workload. Ya no es una ruta lineal de perímetro a interior.

Defecto 2 — capacidades superpuestas: el API Gateway complementa al WAF en vez de duplicarlo. Cada uno cubre una función distinta.

Defecto 3 — sin inteligencia ni respuesta: lo corregimos con cuatro controles en conjunto. Threat Intelligence alimenta el sistema con información actualizada de amenazas. SOAR automatiza la respuesta. UEBA detecta comportamiento anómalo sin necesidad de reglas predefinidas. Y el Red Team anual simula el Cyber Kill Chain completo para validar que todas las defensas realmente funcionan."

SLIDE 14 — LARGO PLAZO: TABLA DE CONTROLES

"La tabla final muestra los ocho controles del largo plazo, todos mapeados a la capa DiD y al defecto que corrigen. Pueden ver que la mayoría apunta al Defecto 3 — que es el más estructural. Zero Trust, SOAR, UEBA, Threat Intelligence y Red Team son todos respuesta a esa limitación fundamental del DiD: ser un modelo de protección estático sin capacidad de adaptación ni respuesta.

Para cerrar: en doce meses, Bankitor pasa de una arquitectura con baja trazabilidad, red plana y sin capacidad de respuesta, a una arquitectura proactiva, con Zero Trust, automatización de respuesta y alineada a la regulación SBS y al marco NIST CSF. Los dos incidentes que motivaron este trabajo se resuelven en los primeros tres meses. Todo lo que viene después construye sobre esa base para que no vuelva a ocurrir."